



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



CVE-2026-42015 Gnutls: gnutls: memory corruption due to off-by-one error in pkcs#12 bag handling

Vulnerability Report

Classification	TLP:CLEAR
Published	2026-06-12
Version	1.0
Author	Lost Boys Cyber
Report Type	Vulnerability Report

TLP:CLEAR | Lost Boys Cyber | CVE-2026-42015 Gnutls: gnutls: memory corruption due to off-by-one error in pkcs#12 bag handling - Vulnerability Report

Published: 2026-06-12 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Intelligence Requirement
3. Source Review and Confidence
4. Key Findings
5. Threat Context
6. Detection and Hunting
7. Recommendations
8. References

CVE-2026-42015 Gnutls: gnutls: memory corruption due to off-by-one error in pkcs#12 bag handling

1. Executive Summary

CVE-2026-42015 is a memory-corruption vulnerability in GnuTLS PKCS#12 bag handling. Upstream, Debian, Red Hat, and the CVE record all describe the same root cause: an off-by-one bounds check when appending an item to a PKCS#12 bag that already contains 32 elements. In the vulnerable path, the library can write past the end of the bag's internal array, creating at least a denial-of-service risk and potentially enabling additional undefined behavior depending on the embedding application.

The immediate defensive concern is not generic TLS traffic. The higher-probability exposure is software that uses GnuTLS to import, construct, transform, or validate attacker-controlled PKCS#12 / PFX material during certificate-management workflows, identity onboarding, secure mail handling, VPN / client-certificate provisioning, or appliance administration. Organizations should therefore treat this as a library-and-workflow exposure problem rather than as a universally reachable internet-facing bug in every GnuTLS deployment.

Public reporting reviewed during this task does not show known in-the-wild exploitation or a CISA KEV listing. However, the issue is now broadly documented across the CVE Program, distro trackers, vendor errata, the upstream security bulletin, and the fixing commit. That means exploitability research and proof-of-concept development are plausible follow-on risks, especially for products that accept external PKCS#12 uploads or synchronize certificates from untrusted sources.

Defender priority should center on confirming which systems use vulnerable GnuTLS builds or backported-but-unpatched package variants, mapping applications that process `.p12` / `.pfx` inputs, and monitoring for crashes or anomalous certificate-import failures around those workflows. Upgrading to GnuTLS 3.8.13 or vendor-fixed backports is the primary remediation path.

2. Intelligence Requirement

Question	Answer
What is the vulnerability?	An off-by-one bounds-check error in GnuTLS PKCS#12 bag handling that can write past the internal array when appending to a bag already containing 32 elements.
What is the primary impact?	Memory corruption leading at minimum to denial of service and potentially other unspecified impacts.
What is most likely exposed?	Applications, services, and appliances that import or manipulate attacker-controlled PKCS#12 / PFX bundles using vulnerable GnuTLS code paths.
What should defenders do first?	Identify GnuTLS-dependent PKCS#12 workflows, verify package versions and vendor backports, patch to GnuTLS 3.8.13 or distro-fixed builds, and monitor for import crashes or repeated certificate-processing failures.

3. Source Review and Confidence

Source	Contribution	Confidence
CVE Program API record	Canonical description, weakness, publication timing, Red Hat CVSS vector, affected-product references	High
GnuTLS upstream security bulletin	Upstream severity, concise flaw statement,	High

	fixed-version guidance (`3.8.13+`)	
Upstream fixing commit `a3e7c50d3e17...`	Exact code-level correction from `==` to `>=` in the bag bounds check	High
Debian security tracker	Distro package exposure and fixed versions across supported Debian releases	High
Red Hat Bugzilla / errata	Operational packaging and remediation evidence for enterprise Linux consumers	High
NVD entry	Additional normalization, CWE tagging, and cross-reference set	Medium
oss-sec release thread	Confirms upstream advisory bundle and public dissemination timing	Medium

Confidence is high that the defect is real, patched, and relevant to PKCS#12-processing code paths. Confidence is only medium on broad remote exploitability because the public sources disagree on practical severity and attack conditions. Upstream labels the issue as Low severity, the CVE/NVD record exposes a 5.3 Medium network vector, and the fixing commit page presents a 6.1 Medium local/UI-required vector. That mismatch suggests defenders should avoid overstating reachability while still treating certificate-import workflows as the likely attack surface.

4.1 Vulnerability Mechanics

The fixing commit for GNUTLS-SA-2026-04-29-11 changes the guard in `gnutls\_pkcs12\_bag\_set\_data()` from an equality check to a greater-than-or-equal check. Public advisory text states that appending to a PKCS#12 bag that already contains 32 elements can write past the bag's internal array. This makes the root cause an off-by-one bounds-check failure in a memory-management path handling PKCS#12 bag elements.

4.2 Practical Exposure Conditions

The available source set supports a narrower exposure interpretation than the raw CVSS vector alone might imply:

- The vulnerable path is tied to PKCS#12 bag manipulation rather than general TLS session handling.
- Exploitation likely requires the target application to ingest, construct, or append data into a PKCS#12 bag derived from attacker-controlled or attacker-influenced input.
- Environments most worth prioritizing include certificate-import portals, enterprise identity tooling, client-certificate enrollment workflows, secure mail products, VPN / middleware products, and appliances that accept PKCS#12 bundles for trust-store or credential onboarding.

4.3 Defensive Implications

Even when remote code execution is not demonstrated publicly, memory corruption in credential-material processing deserves prompt remediation because:

- crashes in certificate-management services can create localized outages at high-trust control points;
- admin or automation workflows may repeatedly process the same malicious bundle, turning a single crafted file into a durable operational hazard;
- vendor appliances and statically linked products can remain exposed after base OS patching if they bundle their own GnuTLS copy or lag behind distro backports.

4.4 Severity and Exposure Summary

Dimension	Assessment	Notes
Vulnerability class	Memory corruption / out-of-bounds write	CVE text and upstream advisory align
Likely immediate outcome	Crash / denial of service	Explicitly stated in public records

Potential for deeper impact	Plausible but unproven publicly	CVE record says "other unspecified impacts"
Broad internet wormability	Low confidence	Public evidence does not support this claim
Highest-priority exposure	PKCS#12 import / certificate-management workflows	Most directly aligned with the affected function
Remediation urgency	High for exposed workflows	Fixed upstream in 3.8.13 and in multiple distro backports

5. Threat Context

There is no public evidence in the reviewed source set that CVE-2026-42015 is under mass exploitation, included in CISA's Known Exploited Vulnerabilities catalog, or tied to a named campaign. That reduces the likelihood of immediate opportunistic exploitation at internet scale, but it does not eliminate targeted abuse against certificate-handling workflows.

Threat context that matters to defenders:

- PKCS#12 bundles are commonly exchanged during certificate import, device enrollment, identity migration, VPN provisioning, and appliance administration.
- Those workflows often run in privileged or operationally sensitive contexts, making even a denial-of-service condition meaningful.
- Once a vulnerability is documented across advisory feeds, distro trackers, and a public fixing commit, adversaries have enough information to begin building targeted reproducers.

Representative attack scenarios:

- 1. Administrative import surface abuse
- An attacker supplies a crafted PKCS#12 file to an appliance or management portal that accepts certificate bundles.
- The service parses or appends bag elements into a vulnerable structure.
- The import workflow crashes, disrupting onboarding or trust-store operations.
- 2. Partner or customer certificate exchange abuse
- A business workflow ingests externally supplied `.p12` / `.pfx` bundles for B2B onboarding, mail security, or client-authentication setup.
- A malformed bundle reaches a vulnerable GnuTLS-backed processing path.
- The result is a crash or unstable certificate-processing state.
- 3. Supply-chain lag and bundled-library exposure
- The platform team patches base Linux packages, but a vendor application or container includes an older embedded GnuTLS build.
- Security teams assume the issue is closed while the application remains vulnerable.

6.1 Detection Coverage Summary

Signal	Telemetry Source	Defensive Value
Crashes or segfaults in certificate-processing services	Syslog, journald, EDR process telemetry	Strongest post-event indicator for this flaw class
Repeated PKCS#12 / PFX import failures	Application logs, admin portal logs, middleware logs	Can reveal malformed-bundle abuse or failed exploit attempts
Presence of vulnerable GnuTLS versions	Package inventory, SBOM, container manifests	Best proactive exposure detection
Uploads or file touches involving `.p12` / `.pfx` near service instability	File telemetry, web/app logs, audit logs	Helps correlate hostile inputs to crashes

Bundled GnuTLS libraries in appliances or containers	SBOM / image scanning / binary inventory	Detects exposure missed by OS package patching
--	--	--

6.2 Sigma Rule

```

title: Possible GnuTLS PKCS12 Processing Crash or Failure
id: 4b7e7f73-f4d0-4d46-9778-gnutls-pkcs12-42015
status: experimental
description: Detects Linux application logs that suggest a crash or repeated failure while processing
PKCS#12/PFX material in software using GnuTLS.
logsource:
  product: linux
  service: application
  category: application

detection:
  keywords_gnutls:
    message|contains:
      - 'gnutls'
      - 'pkcs12'
      - 'pfx'
      - 'certificate import'
  failure_terms:
    message|contains:
      - 'segmentation fault'
      - 'core dumped'
      - 'out of bounds'
      - 'memory corruption'
      - 'import failed'
      - 'crash'
  condition: keywords_gnutls and failure_terms
falsepositives:
  - Benign certificate parsing errors
  - Expected failures during certificate-format validation testing
level: medium
tags:
  - attack.t1190
  - attack.t1499

```

6.3 Microsoft Defender KQL Hunt Query

```

// Look for Linux hosts with certificate-processing activity, PKCS#12/PFX file touches,
// and nearby crash-like events that could align with malformed bundle handling.
let CrashTerms = dynamic(["segfault", "segmentation fault", "core dumped", "memory corruption", "out of
bounds", "crash"]);
let PfxTerms = dynamic([".p12", ".pfx", "pkcs12", "certificate import"]);
DeviceFileEvents
| where Timestamp > ago(30d)
| where FileName endswith ".p12" or FileName endswith ".pfx" or FolderPath has_any ("pkcs12", "pfx")
| project FileTouchTime=Timestamp, DeviceName, FileName, FolderPath, SHA1, InitiatingProcessFileName,
InitiatingProcessCommandLine
| join kind=leftouter (
  DeviceEvents
  | where Timestamp > ago(30d)
  | where ActionType has_any ("Crash", "ApplicationCrash", "Fault") or AdditionalFields has_any
(CrashTerms)
  | project CrashTime=Timestamp, DeviceName, ActionType, AdditionalFields, InitiatingProcessFileName,
InitiatingProcessCommandLine
) on DeviceName
| where isnull(CrashTime) or (CrashTime between (FileTouchTime-30m .. FileTouchTime+30m))
| order by FileTouchTime desc

```

6.4 Splunk Hunt Query

```

(index=syslog OR index=linux OR index=app_logs)
("gnutls" OR "pkcs12" OR ".p12" OR ".pfx" OR "certificate import")

```

```

("segmentation fault" OR "core dumped" OR "memory corruption" OR "out of bounds" OR "import failed" OR
"crash")
| stats count min(_time) as first_seen max(_time) as last_seen values(host) as hosts values(process) as
processes values(source) as sources by message
| convert ctime(first_seen) ctime(last_seen)
| sort - count

```

6.5 Threat-Hunting Leads

- Identify all enterprise workflows that ingest PKCS#12 / PFX material from external parties, administrators, or automated synchronization jobs.
- Review application and middleware logs for crashes, import failures, or restart loops immediately after certificate-bundle processing.
- Inventory whether exposed products rely on distro-fixed packages, bundled GnuTLS copies, or containers with stale libraries.
- Review change-control or help-desk records for unexplained certificate-import failures after 2026-05-26, the public CVE publication date.

7. Recommendations

Priority	Owner	Recommendation	Rationale
Immediate	Vulnerability Management / Platform	Upgrade to GnuTLS 3.8.13 or apply vendor-fixed backports for affected distributions and products.	Primary remediation path confirmed by upstream and distro advisories.
Immediate	Application Owners	Inventory applications, appliances, containers, and services that process PKCS#12 / PFX bundles through GnuTLS-backed workflows.	Exposure depends heavily on the embedding workflow, not merely package presence.
High	Engineering / PKI Operations	Temporarily restrict or rate-limit untrusted PKCS#12 imports where practical until patching is complete.	Reduces reachable attack surface on certificate-management paths.
High	SOC / Detection Engineering	Monitor for crashes, repeated import failures, and `.p12` / `.pfx` handling anomalies on certificate-processing systems.	Best available post-exploitation and failed-attempt signals.
High	Asset / Supply-Chain Management	Use SBOM, image scanning, and vendor outreach to identify bundled GnuTLS copies not covered by OS patching.	Prevents false closure after only base-package remediation.
Medium	Incident Response	Preserve malformed certificate bundles, crash dumps, and relevant logs if suspicious failures are observed.	Supports root-cause analysis and potential exploit confirmation.

Additional analyst notes:

- Do not assume every GnuTLS consumer is directly reachable through this flaw; prioritize certificate-import and PKCS#12-processing functions first.

- Treat severity disagreements in the public record as a cue to scope exposure carefully, not as a reason to defer remediation.
- If a business-critical product accepts uploaded PKCS#12 bundles and cannot be patched quickly, isolate the workflow operationally and require trusted-source handling until remediation lands.

8. References

- 1. Microsoft Security Update Guide intake item, `CVE-2026-42015`
- <https://msrc.microsoft.com/update-guide/vulnerability/CVE-2026-42015>
- 2. CVE Program API record, `CVE-2026-42015`
- <https://cveawg.mitre.org/api/cve/CVE-2026-42015>
- 3. NVD CVE 2.0 API, `CVE-2026-42015`
- <https://services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2026-42015>
- 4. GnuTLS upstream security bulletin, `GNUTLS-SA-2026-04-29-11`
- <https://www.gnutls.org/security-new.html#GNUTLS-SA-2026-04-29-11>
- 5. GnuTLS fixing commit `a3e7c50d3e1761e5ef1d4b225507cab8f2b2c3ca`
- <https://gitlab.com/gnutls/gnutls/-/commit/a3e7c50d3e1761e5ef1d4b225507cab8f2b2c3ca>
- 6. Debian security tracker, `CVE-2026-42015`
- <https://security-tracker.debian.org/tracker/CVE-2026-42015>
- 7. Red Hat CVE / Bugzilla tracking, `CVE-2026-42015`
- https://bugzilla.redhat.com/show_bug.cgi?id=2467678
- 8. Red Hat advisory example, `RHSA-2026:20611`
- <https://access.redhat.com/errata/RHSA-2026:20611>
- 9. oss-sec release announcement for `gnutls 3.8.13`
- <https://seclists.org/oss-sec/2026/q2/288>